RAPPORT DE SPÉCIFICATION D'API

Plateforme de gestion des stages / PFE

Contrat d'API REST : conventions, sécurité, endpoints et modèle de données

Élément	Valeur
Version de la spécification	0.1.0-draft (OpenAPI 3.1.0)
Statut	Brouillon de conception à valider par l'équipe. Aucune implémentation ni test à ce stade.
URL de base	`https://api.pfe-fst.example/api/v1` (hôte fictif, TLS terminé par Nginx)
Périmètre	67 opérations réparties en 14 domaines
Licence	Usage académique

1. Présentation

1.1 Rôles

Rôle	Création du compte	Usage principal
STUDENT (ETU)	Inscription libre	Téléverser ses CV, postuler, suivre ses candidatures, déposer ses rapports
COMPANY_MANAGER (RESP)	Inscription entreprise, puis validation par un administrateur	Gérer offres, candidatures, tuteurs, conventions ; consulter le matching IA
COMPANY_TUTOR (TUT)	Créé par le responsable entreprise, activation par code	Commenter les rapports, évaluer le stagiaire
ACADEMIC_SUPERVISOR (ENC)	Créé par un administrateur, activation par code	Commenter les rapports, noter le rapport final
ADMIN (ADM)	Créé par un administrateur, activation par code	Valider entreprises et conventions, gérer utilisateurs, base RAG, journal d'audit

2.1 Codes de refus

Code	Signification	Remarque
401	Non authentifié	Jeton invalide ou expiré, identifiants invalides ; message générique
403	Fonction interdite pour ce rôle (BFLA)	Aucun détail sur le rôle requis
404	Objet absent ou hors périmètre (BOLA)	Réponse identique dans les deux cas (anti-énumération)
409	État incompatible ou doublon	`INVALID_STATE_TRANSITION` pour les transitions interdites
413 / 415	Fichier trop volumineux / type non accepté	PDF réel exigé
422	Validation	Type, longueur, format ou champ inconnu
429	Limitation de fréquence	En-tête `Retry-After`
502	Service IA indisponible ou sortie LLM invalide	`LLM_OUTPUT_INVALID`, message générique

3. Sécurité

3.1 Authentification

- JWT d'accès d'environ 15 minutes, transmis en `Authorization: Bearer`. Signature et claims (`exp`, `iss`, `aud`) vérifiés.
- Refresh token rotatif : cookie `HttpOnly; Secure; SameSite=Strict` côté web, corps de réponse côté mobile (stockage Keychain/Keystore).
- Un refresh token déjà utilisé révoque toute sa famille (détection de rejeu).
- Échec de connexion : `401 INVALID_CREDENTIALS` identique que l'e-mail existe ou non. `403 ACCOUNT_NOT_ACTIVE` uniquement si le mot de passe est correct.

- Mot de passe : 12 à 128 caractères, aucune règle de composition, contrôle contre une liste de mots de passe courants.
- Le changement de mot de passe et la désactivation d'un compte révoquent les refresh tokens.

3.2 Autorisation

Le rôle et le statut du compte sont relus en base à chaque requête : un identifiant fourni par le client n'est jamais une preuve d'autorisation. Chaque opération documente ses rôles et sa règle de propriété dans l'extension `x-authz`.

- **BOLA (accès à un objet)** : un objet hors périmètre renvoie 404. Exemple du projet : un étudiant qui lit `/applications/43` sans en être propriétaire reçoit 404.
- **BFLA (accès à une fonction)** : un rôle non autorisé reçoit 403 et un événement `ACCESS_DENIED` est journalisé. Exemple du projet : validation d'une convention par un non-administrateur.
- Le filtre de propriété est appliqué dans la requête elle-même ; les paramètres de filtre (par exemple `offer_id`) n'élargissent jamais le périmètre autorisé.

3.3 Champs interdits côté client

Le client ne peut jamais fournir `role`, `status`, `owner`, ni `company_id` (déduit du compte), ni `grade` hors de l'endpoint dédié. Les schémas d'entrée utilisent `additionalProperties: false` : tout champ inconnu est rejeté en 422.

3.4 Minimisation des données

- La vue entreprise d'une candidature n'expose ni e-mail ni téléphone de l'étudiant (API3).
- `grade` n'est visible que de l'étudiant propriétaire et de l'encadrant affecté.
- Les réponses d'inscription sont volontairement minimales et ne confirment pas l'existence d'autres comptes.

3.5 Téléversements

Usage	Taille maximale	Endpoint
CV	5 Mo	`POST /me/cvs`
Rapport	10 Mo	`POST /internships/{id}/reports`
Document RAG	20 Mo	`POST /admin/rag-documents`

3.7 Fonctions IA

- **Matching CV ↔ offre** : le texte du CV est traité comme une donnée non fiable, isolée du prompt. La sortie du LLM est validée par schéma (score entier 0 à 100, justification en texte brut) ; toute sortie invalide est rejetée en 502. Le score est **consultatif** : il ne modifie jamais le statut d'une candidature.
- **Assistant RAG** : les documents sont filtrés par rôle (`allowed_roles`) avant la recherche vectorielle. La réponse est rendue en texte brut, jamais en HTML. Le LLM est local : aucune donnée n'est envoyée à une API externe.
- Les textes saisis par les utilisateurs (offres, commentaires) sont échappés à l'affichage pour prévenir le XSS stocké.

4. Cycles de vie des statuts

Entité	Statuts	Transitions (endpoint)
Compte	`PENDING_ACTIVATION`, `PENDING_VALIDATION`, `ACTIVE`, `DISABLED`	Activation par code (`/auth/activate`) ; activation du responsable à la validation de son entreprise ; `/admin/users/{id}/status` ; désactivation d'un tuteur
Entreprise	`PENDING_VALIDATION`, `VALIDATED`, `REJECTED`, `SUSPENDED`	PENDING_VALIDATION → VALIDATED (validate) ou REJECTED (reject). Aucun endpoint pour SUSPENDED.
Offre	`DRAFT`, `PUBLISHED`, `CLOSED`	DRAFT → PUBLISHED (publish) → CLOSED (close). Suppression possible en DRAFT uniquement.
Candidature	`SUBMITTED`, `UNDER_REVIEW`, `ACCEPTED`, `REJECTED`, `WITHDRAWN`	SUBMITTED → UNDER_REVIEW (start-review) → ACCEPTED (accept, génère la convention) ou REJECTED (reject) ; WITHDRAWN par l'étudiant (withdraw)
Convention	`GENERATED`, `APPROVED_BY_COMPANY`, `VALIDATED`, `REJECTED`, `CANCELLED`	GENERATED → APPROVED_BY_COMPANY (company-approval) → VALIDATED (admin validate, crée le stage). REJECTED par l'entreprise (depuis GENERATED) ou l'admin (depuis APPROVED_BY_COMPANY). CANCELLED par l'admin si non validée.
Stage	`ONGOING`, `COMPLETED`	Créé à la validation de la convention. Aucune transition exposée dans la spécification.

Toute transition interdite depuis l'état courant renvoie 409 `INVALID_STATE_TRANSITION`.

5. Endpoints par domaine

5.2 Authentification

Méthode	Chemin	Rôles	Description
POST	`/auth/register/student`	PUB	Créer un compte étudiant (rôle imposé côté serveur)
POST	`/auth/register/company`	PUB	Créer un compte entreprise, en attente de validation administrative
POST	`/auth/activate`	PUB	Activer un compte créé par un tiers (code à usage unique) et choisir son mot de passe
POST	`/auth/login`	PUB	S'authentifier (web : cookie refresh ; mobile : refresh dans le corps)
POST	`/auth/refresh`	PUB	Renouveler le jeton d'accès (rotation du refresh token)
POST	`/auth/logout`	Tous	Se déconnecter (révoque refresh et jeton d'accès courant)
POST	`/auth/password/change`	Tous	Changer son mot de passe (actuel et nouveau requis)

5.3 Profil

Méthode	Chemin	Rôles	Description
GET	/me	Tous	Consulter son profil
PATCH	/me	Tous	Modifier son profil (champs autorisés uniquement)

5.4 Entreprise

Méthode	Chemin	Rôles	Description
GET	/companies/me	RESP	Consulter son entreprise
GET	/companies/me/tutors	RESP	Lister les tuteurs de son entreprise
POST	/companies/me/tutors	RESP	Créer un tuteur (compte à activer par code)
POST	/companies/me/tutors/{tutorId}/disable	RESP	Désactiver un tuteur de son entreprise

5.5 Offres

Méthode	Chemin	Rôles	Description
GET	/offers	ETU, RESP	Rechercher des offres (filtres q, location, status, sort)
POST	/offers	RESP	Créer une offre (brouillon)
GET	/offers/{offerId}	ETU, RESP	Consulter une offre
PATCH	/offers/{offerId}	RESP	Modifier une offre non close (statut non modifiable ici)
DELETE	/offers/{offerId}	RESP	Supprimer une offre en brouillon sans candidature
POST	/offers/{offerId}/publish	RESP	Publier (DRAFT → PUBLISHED)
POST	/offers/{offerId}/close	RESP	Clore (PUBLISHED → CLOSED)

5.6 CV

Méthode	Chemin	Rôles	Description
GET	/me/cvs	ETU	Lister ses CV (20 maximum)
POST	/me/cvs	ETU	Téléverser son CV (PDF, 5 Mo max)
DELETE	/me/cvs/{cvId}	ETU	Supprimer un de ses CV (409 si utilisé par une candidature non finale)
GET	/cvs/{cvId}/content	ETU, RESP	Télécharger un CV (propriétaire ou entreprise destinataire d'une candidature liée)

5.7 Candidatures

Méthode	Chemin	Rôles	Description
POST	/offers/{offerId}/applications	ETU	Postuler à une offre (état initial SUBMITTED)
GET	/applications	ETU, RESP	Lister les candidatures de son périmètre (filtres status, offer_id)
GET	/applications/{applicationId}	ETU, RESP	Consulter une candidature (404 hors périmètre)
POST	/applications/{applicationId}/withdraw	ETU	Retirer sa candidature (→ WITHDRAWN)
POST	/applications/{applicationId}/start-review	RESP	Passer en examen (→ UNDER_REVIEW)
POST	/applications/{applicationId}/accept	RESP	Accepter (→ ACCEPTED ; génère la convention)
POST	/applications/{applicationId}/reject	RESP	Refuser (→ REJECTED)

5.8 Matching IA

Méthode	Chemin	Rôles	Description
GET	/applications/{applicationId}/matching	RESP	Consulter le dernier score de compatibilité CV ↔ offre
POST	/applications/{applicationId}/matching	RESP	Calculer ou recalculer le score via le LLM local (502 si sortie invalide)

5.9 Conventions

Méthode	Chemin	Rôles	Description
GET	/conventions	ETU, RESP, ADM	Lister les conventions de son périmètre
GET	/conventions/{conventionId}	ETU, RESP, ADM	Consulter une convention
GET	/conventions/{conventionId}/document	ETU, RESP, ADM	Télécharger le PDF de la convention
POST	/conventions/{conventionId}/company-approval	RESP	Approuver (GENERATED → APPROVED_BY_COMPANY)
POST	/conventions/{conventionId}/company-rejection	RESP	Refuser côté entreprise (GENERATED → REJECTED), motif requis
POST	/admin/conventions/{conventionId}/validate	ADM	Valider (APPROVED_BY_COMPANY → VALIDATED ; crée le stage)
POST	/admin/conventions/{conventionId}/reject	ADM	Rejeter (APPROVED_BY_COMPANY → REJECTED), motif requis
POST	/admin/conventions/{conventionId}/cancel	ADM	Annuler une convention non validée (→ CANCELLED), motif requis

5.10 Stages

Méthode	Chemin	Rôles	Description
GET	/internships	ETU, RESP, TUT, ENC, ADM	Lister les stages de son périmètre
GET	/internships/{internshipId}	ETU, RESP, TUT, ENC, ADM	Consulter un stage
PUT	/internships/{internshipId}/company-tutor	RESP	Affecter un tuteur entreprise (de sa propre entreprise, ACTIVE)
PUT	/admin/internships/{internshipId}/academic-supervisor	ADM	Affecter un encadrant académique (rôle ACADEMIC_SUPERVISOR, ACTIVE)

5.11 Rapports

Méthode	Chemin	Rôles	Description
GET	/internships/{internshipId}/reports	ETU, TUT, ENC	Lister les rapports d'un stage (filtre type)
POST	/internships/{internshipId}/reports	ETU	Déposer un rapport PROGRESS ou FINAL (PDF, 10 Mo max, stage ONGOING)
GET	/reports/{reportId}	ETU, TUT, ENC	Consulter les métadonnées (grade selon la règle API3)
GET	/reports/{reportId}/content	ETU, TUT, ENC	Télécharger le rapport (PDF)
GET	/reports/{reportId}/comments	ETU, TUT, ENC	Lister les commentaires
POST	/reports/{reportId}/comments	TUT, ENC	Commenter (texte brut, échappé à l'affichage)
PUT	/reports/{reportId}/grade	ENC	Noter le rapport FINAL (0–20, pas de 0,25)

5.12 Évaluations

Méthode	Chemin	Rôles	Description
GET	/internships/{internshipId}/company-evaluation	ETU, TUT, ENC	Consulter la fiche d'évaluation entreprise
PUT	/internships/{internshipId}/company-evaluation	TUT	Évaluer le stagiaire (note 0–20, commentaire)

5.13 Assistant RAG

Méthode	Chemin	Rôles	Description
POST	/assistant/queries	Tous	Interroger l'assistant réglementaire (documents filtrés par rôle)

5.14 Administration

Méthode	Chemin	Rôles	Description
GET	/admin/users	ADM	Lister les utilisateurs (filtres role, status, q)
POST	/admin/users	ADM	Créer un encadrant académique ou un administrateur
GET	/admin/users/{userId}	ADM	Consulter un utilisateur
PUT	/admin/users/{userId}/status	ADM	Activer ou désactiver un compte (pas d'auto-désactivation)
GET	/admin/companies	ADM	Lister les entreprises (filtre status)
POST	/admin/companies/{companyId}/validate	ADM	Valider une entreprise (PENDING_VALIDATION → VALIDATED)
POST	/admin/companies/{companyId}/reject	ADM	Rejeter une entreprise (→ REJECTED), motif requis
GET	/admin/rag-documents	ADM	Lister la base documentaire du RAG
POST	/admin/rag-documents	ADM	Ajouter un document PDF (20 Mo max) avec ses rôles autorisés
DELETE	/admin/rag-documents/{documentId}	ADM	Retirer un document du RAG et de l'index
GET	/admin/audit-logs	ADM	Consulter le journal d'audit (lecture seule)

6. Modèle de données

Principaux schémas de la spécification (les schémas d'entrée interdisent les champs inconnus).

6.1 Énumérations

Énumération	Valeurs
Role	STUDENT, COMPANY_MANAGER, COMPANY_TUTOR, ACADEMIC_SUPERVISOR, ADMIN
AccountStatus	PENDING_ACTIVATION, PENDING_VALIDATION, ACTIVE, DISABLED
CompanyStatus	PENDING_VALIDATION, VALIDATED, REJECTED, SUSPENDED
OfferStatus	DRAFT, PUBLISHED, CLOSED
ApplicationStatus	SUBMITTED, UNDER_REVIEW, ACCEPTED, REJECTED, WITHDRAWN
ConventionStatus	GENERATED, APPROVED_BY_COMPANY, VALIDATED, REJECTED, CANCELLED
InternshipStatus	ONGOING, COMPLETED
ReportType	PROGRESS, FINAL

6.2 Entités

Schéma	Champs principaux	Contraintes notables
Me / AdminUser	id, email, first_name, last_name, role, status, created_at ; program, phone, company_id selon le rôle	MeUpdate n'accepte que first_name, last_name, program, phone

Schéma	Champs principaux	Contraintes notables
`Company`	id, name, registration_number, sector, address, status, created_at	Nom de 2 à 150 caractères à l'inscription
`Offer`	id, company_id, company_name, title, description, location, start_date, application_deadline, status, published_at	Titre 3–150 ; description 10–5000
`Cv`	id, display_filename, size_bytes, uploaded_at	size_bytes ≤ 5 242 880
`Application`	id, offer_id, offer_title, company_name, student, cv_id, cover_letter, status, submitted_at, decided_at, decision_reason	Vue étudiant limitée à id, nom, prénom, program ; lettre ≤ 3000
`MatchingResult`	application_id, score, justification, model_name, generated_at, advisory	score entier 0–100 ; advisory toujours `true`
`Convention`	id, application_id, status, generated_at, company_approved_at, validated_at, rejection_reason	Motif de 3 à 500 caractères pour refus et annulation
`Internship`	id, convention_id, student, company_id, company_tutor, academic_supervisor, start_date, end_date, status	Tuteur et encadrant nullables
`Report`	id, internship_id, type, display_filename, size_bytes, submitted_at, grade, graded_at	grade 0–20 par pas de 0,25, rapport FINAL uniquement
`ReportComment`	id, report_id, author, content, created_at	Contenu 1–2000, texte brut
`CompanyEvaluation`	internship_id, overall_score, comments, submitted_at	Note 0–20 par pas de 0,25 ; commentaire ≤ 3000
`AssistantQuery` / `AssistantAnswer`	question ; answer, sources (document_id, title)	Question 3–1000 ; 10 sources maximum
`RagDocument`	id, title, allowed_roles, indexed_at, created_at	Au moins un rôle autorisé
`AuditLogEntry`	id, actor_id, action, resource_type, resource_id, outcome, ip_address, request_id, created_at	outcome : SUCCESS, DENIED ou FAILURE ; lecture seule

7. Points ouverts

Éléments relevés dans la spécification, à trancher avant implémentation.

- **Valeurs proposées** : limites de fréquence, tailles de fichiers et échelle de notation sur 20 sont des hypothèses à valider.
- **Chemin de validation d'une convention** : le document du projet cite POST `/admin/conventions/validate` ; la spécification porte l'identifiant dans le chemin. Variante à valider avec l'équipe.
- **Références OWASP** : les identifiants du Top 10 LLM (LLM01, LLM02) sont à re-vérifier selon le référentiel du projet. Exigences ASVS : voir `exigences-asvs.md` (ASVS 5.0.0).
- **Stage** : aucun endpoint ne fait passer un stage de `ONGOING` à `COMPLETED`.
- **Entreprise** : le statut SUSPENDED existe mais aucun endpoint ne le produit.
- **Mot de passe oublié** : aucun parcours de réinitialisation n'est décrit ; seul le changement de mot de passe connecté existe.
- **Code d'activation** : le canal de remise du code (e-mail, autre) n'est pas précisé.

- **Lecture des rapports et évaluations** : le responsable entreprise et l'administrateur n'ont pas accès aux rapports ni à la fiche d'évaluation. À confirmer si ce choix est voulu.